

A sharp distribution-free certificate for catastrophic multi-service outage under security-control portfolios

2026-09-20 (working note, version 0.1.0)

Abstract

A hospital's concern is not that *some* clinical service is disrupted but that *several critical services fail at once*. We certify exactly that: the probability that at least k of the n clinical services suffer simultaneous sustained outage stays below a level ε , under an ATT&CK-driven attack model and interval uncertainty. The bound on the k -of- n event is the sharp distribution-free maximum over all joint outcomes consistent with the per-service marginals – a small linear program over the 2^n outcome atoms – which replaces the loose union bound used previously (its $k=1$ special case). Because the catastrophic event is rarer than "any one service", it is far more certifiable: at $\varepsilon = 5\%$ the minimum guaranteed control count falls from 3 controls for $k=1$ to 1 for $k=3$, and the hospital-core bundle, *not* certified for "at least one service" (no), *is* certified for the two-, three-, and all-service catastrophic events (yes/yes/yes). The aggregation bound is classical (Frechet/Boole/linear programming); the contribution is the sharp, clinically meaningful certificate, not a new theorem.

1 The k-of-n bound

Given only the per-service outage marginals $p_1, \dots, p_n$ (here $p_s = R d_s$: kill-chain impact reachability times a service's degradation probability), the largest possible probability that at least k services fail together, over every joint distribution with those marginals, is

$$\max_{\text{joints}} \Pr\left(\sum_s \mathbf{1}[s \text{ down}] \geq k\right),$$

a linear program over the 2^n outcome atoms with the marginals and total mass as equality constraints. Its optimum is attained by an explicit joint, so the bound is sharp. It equals the union bound $\min(1, \sum_s p_s)$ at $k = 1$, equals $\min_s p_s$ at $k = n$, is monotone non-decreasing in each marginal, and is strictly tighter than the union (and than the Markov bound $\sum p_s/k$) for $k \geq 2$. Monotonicity in the marginals – which are themselves monotone in the model parameters – means the worst case over the interval uncertainty set is still an interval corner, so the sharp bound drops into the existing corner certificate unchanged.

2 Result

Under the ATT&CK-driven hospital (v17.1) with the evidence-anchored intervals, the undefended probability of "at least one" clinical service in sustained outage is 44.9%, but the all-four catastrophic event is only 9.9%. The certifiable control burden falls sharply with the catastrophic threshold

Table 1: Minimum guaranteed control count at $\varepsilon = 5\%$ and undefended worst-case probability, by catastrophic threshold k , under assumed and CIPHER-derived degradation.

k	Undefended (%)	Min controls	Undefended, CIPHER (%)	Min controls, CIPHER
1	44.9	3	33.0	3
2	22.5	2	16.5	1
3	15.0	1	11.0	1
4	9.9	1	7.0	1

Table 2: Named control bundles: whether each is guaranteed at $\varepsilon = 5\%$ for the k -of-four catastrophic event (assumed degradation).

Bundle	Size	$k=1$	$k=2$	$k=3$	$k=4$
identity	4	yes	yes	yes	yes
backup	1	no	no	no	no
segmentation	1	no	no	no	no
patching	1	no	no	no	no
detection	2	no	no	no	no
hospital core	5	no	yes	yes	yes

(Table 1): at $\varepsilon = 5\%$, guaranteeing "at least one service" needs 3 controls, "at least two" needs 2, and "at least three" or "all four" need 1. The hospital-core bundle shows the same lesson at the portfolio level (Table 2): it cannot certify the single-service event but does certify every genuinely catastrophic one. Grounding the degradation in the real CIPHER corpus lowers the burden further (final column of Table 1). The policy reading: a modest, well-chosen portfolio can *provably* bound the risk of a system-wide clinical collapse even when it cannot bound every isolated disruption.

3 Limitations

The sharp aggregation bound is classical; this note contributes its use to certify the clinically defined catastrophic event and its composition with the interval certificate. The marginals inherit every limitation of the underlying model: ATT&CK *mitigates* edges are qualitative, effectiveness and degradation are evidence-anchored intervals rather than measurements, and there is no incident validation. The bound uses only marginals, so it is agnostic to the true dependence between service failures – deliberately, since that dependence is unknown; a validated dependence model could only tighten it.

Reproducibility. All numbers are generated from committed tables; the analysis is deterministic and carries a provenance manifest over the pinned ATT&CK bundle and the CIPHER corpus.